Actividad 8 — Analizar un escenario de seguridad

Considera la siguiente situación:

Una empresa almacena los siguientes elementos:

- nombre
- correo electrónico
- contraseña
- RFC
- información financiera
- claves criptográficas

La base de datos utiliza usuarios y roles correctamente.

Sin embargo:

- las contraseñas están almacenadas en texto claro
- el RFC está almacenado en texto claro
- las conexiones utilizan una configuración sin validación adecuada del servidor
- las claves criptográficas aparecen en archivos SQL
- los respaldos se almacenan sin protección adicional

Responde:

Pregunta 1

¿Cuáles son los principales riesgos?

Los principales riesgos son la exposición de información confidencial y el acceso no autorizado a los datos de la empresa. Al almacenar las contraseñas en texto claro, una persona que obtenga acceso a la base de datos podría conocerlas directamente. El RFC y la información financiera también podrían quedar expuestos. Además, la falta de validación adecuada del servidor en las conexiones aumenta el riesgo de conectarse a un servidor falso o sufrir ataques de intermediario. La publicación de claves criptográficas en archivos SQL podría permitir descifrar información protegida, mientras que los respaldos sin protección podrían ser robados y utilizados para obtener datos confidenciales.

Pregunta 2
¿Qué mecanismo utilizarías para cada elemento?

Elemento	Mecanismo de protección
Nombre	Control de acceso mediante roles y permisos, limitando su consulta a usuarios autorizados.
Correo electrónico	Control de acceso y cifrado cuando el nivel de confidencialidad lo requiera.
Contraseña	Hash seguro con bcrypt, sin almacenarla en texto claro.
RFC	Cifrado de datos en reposo, con gestión segura de las claves de cifrado.
Información financiera	Cifrado en reposo, permisos restrictivos y auditoría de accesos.
Claves criptográficas	Almacenamiento en un gestor de secretos o de claves, fuera de los archivos SQL y del repositorio Git.
Conexiones a PostgreSQL	TLS con validación del certificado y de la identidad del servidor.
Respaldos	Cifrado de los archivos, almacenamiento en un lugar protegido y control de acceso.

Pregunta 3

¿Cuál de los problemas consideras más crítico y por qué?

Considero que el almacenamiento de contraseñas en texto claro es uno de los problemas más críticos, porque cualquier persona que consiga acceso de lectura a la tabla podría obtener las credenciales originales. Además, si los usuarios reutilizan esas contraseñas en otros servicios, el impacto podría extenderse más allá de la base de datos. Por ello, las contraseñas deben almacenarse mediante un algoritmo de hash diseñado específicamente para ellas, como bcrypt. La exposición de las claves criptográficas también es crítica, ya que puede comprometer la confidencialidad de todos los datos protegidos con esas claves.

Pregunta 4

¿Tener correctamente configurados los usuarios y permisos elimina estos riesgos?

No. Tener usuarios y permisos correctamente configurados reduce el riesgo de accesos no autorizados, pero no elimina todos los problemas de seguridad. Si una persona autorizada consulta una contraseña almacenada en texto claro, podrá verla; de igual forma, las claves expuestas en archivos SQL o los respaldos sin protección pueden comprometer la información. Por eso, es necesario combinar el control de acceso con el hash de contraseñas, el cifrado de datos, TLS con validación del servidor, la gestión segura de claves y la protección de los respaldos.